

Bank AI Due Diligence & Data Boundaries

How to evaluate the proposed service, trace information flows, and turn vendor claims into reviewable evidence

Clear boundaries. Relevant evidence. Informed decisions.

A useful AI demonstration does not answer every question about customer information, access, or operational control. This guide helps bank teams define the actual arrangement, assess the evidence, and keep unresolved issues visible before expanding the work.

01

Map the information paths

02

Examine the evidence

03

Record the decision and gaps

For security, risk, compliance, technology, and vendor-management teams

An educational guide with a worked review example and a concise evidence register.

01 / THE REVIEW QUESTION

Evaluate the arrangement, not the label.

Terms such as private, local, secure, and bank-hosted are starting points for questions. They are not a complete description of what happens to information.

Begin with the specific service the bank proposes to use: the work, people, information, tools, providers, and permitted actions. An assistant drafting from approved public material is a different arrangement from one that reads customer files, reaches external services, or updates a production record. A familiar product name does not make those arrangements equivalent.

Vendor statement	Useful follow-up question	Evidence to examine
The service is private.	Private from whom, for which information, and across which processing and support paths?	Service-specific information map, access design, settings, and terms.
It runs at the bank.	Which operations run there, and which optional functions contact another service?	Deployment inventory and configuration-specific tests.
It is read-only.	Read-only for the source system, or also unable to transmit, export, or create other files?	Separate source, tool, output, and distribution permissions.
We have an assurance report.	Which service, period, controls, exceptions, and customer responsibilities does it cover?	The relevant report and a documented applicability review.

Separate usefulness from permission to proceed

A polished output is evidence about one demonstration. It is not proof of appropriate access, dependable recovery, complete contractual protection, or acceptable handling of customer information. Those questions need their own evidence and accountable reviewers. Strong results on one dimension do not erase a serious unresolved issue on another.

A practical due-diligence sequence

Define the service → map information and actions → request relevant evidence → test the bank’s configuration → record gaps and decisions → monitor changes. This is an educational review method, not an official examination checklist or approval.

The interagency community-bank guide describes oversight across the third-party relationship and emphasizes that bank responsibilities remain. Match review effort to the proposed activity, its consequences, and the bank’s circumstances rather than treating every use as identical. [1]

Reading path: scope and boundaries, pages 2–6; evidence and controls, pages 7–10; fictional review, pages 11–12; monitoring and supporting tools, pages 13–15; sources, page 16. Page references follow the PDF; Word pagination may vary.

02 / WRITE THE SERVICE BOUNDARY

Define the service before the review.

A precise service description turns a broad security questionnaire into a review of a real operating arrangement.

Define	What belongs in the description
Work and consequence	The business task, accepted deliverable, intended use, impact of a wrong result, and actions deliberately excluded.
Information	Approved data classes and sources, derived outputs, sensitive context, and information that must not enter the workflow.
People and identities	Requesters, operators, reviewers, administrators, support personnel, and the accounts each role uses.
Environment and providers	Bank-controlled components, hosted services, optional connections, subcontractors, support paths, and relevant locations.
Authority and ownership	Who approves the scope, who owns the information, who accepts the result, and who can change the configuration.
Operating dependence	Expected workload, service criticality, fallback process, recovery needs, support, and the cost of interruption.

Classify what the work can reveal

Classify information using the bank’s own scheme. Public content, internal procedures, employee information, customer records, and restricted investigations can require different handling. Removing a name does not necessarily remove sensitivity: combinations of dates, transactions, or context may still identify a person or reveal confidential activity.

Treat summaries, extracted fields, indexes, screenshots, and draft answers according to what they contain. A confidential document does not become public because its contents were rewritten. Use genuinely synthetic examples for early evaluation, and confirm that sample filenames, metadata, or embedded images do not carry real information inadvertently.

Name the decisions and their owners

The sponsor defines the business need. Source owners and security teams address information and access. Technology owns the deployed configuration and recovery arrangements. Risk, compliance, vendor management, and legal colleagues determine applicable reviews and commitments. These are responsibilities, not a mandatory staffing chart; required expertise and independence must remain.

Do not request everything by default.

An evidence request should explain which question it answers. A limited document-preparation trial and a critical customer-facing service can justify different depth, but neither should proceed on assumptions about undisclosed data paths or missing authority.

03 / FOLLOW THE INFORMATION

Map the copies, not just the original.

Storage, processing, access, retention, and distribution are separate questions. The information map should make each one visible.

Approved source → preparation and retrieval → processing → draft output → review and return.
At every step, also trace logs, temporary copies, indexes, backups, support, and exports.

Path to inspect	What may travel or remain	What to establish
Input and retrieval	Uploaded files, copied passages, prompts, attachments, metadata, and search queries.	Information permitted, user entitlement, and approved source versions.
Processing	Selected content or derived representations used by a local or external operation.	Actual service, configuration, location, and transfer conditions.
Output and sharing	Drafts, citations, summaries, downloadable files, exports, and notifications.	Authorized recipients, destination, and whether a separate send is possible.
Operational records	Conversation history, diagnostics, usage records, caches, indexes, and backups.	Content captured, access, purpose, retention, and deletion handling.
Support and dependencies	Remote access, support bundles, monitoring services, and connected providers.	Approval, duration, scope, subcontractors, and evidence of activity.

Distinguish the base service from optional paths

A local document comparison can be configured differently from online research, an application connection, or a support session. Record optional paths as enabled, disabled, or not yet evaluated. A hidden button is not proof of a blocked transfer, and a disabled feature should be tested in the deployed environment where its boundary matters.

Indexes and embeddings are derived representations that can retain sensitive relationships or link back to source content. Do not assume they are anonymous or harmless. Ask how retrieval respects access changes, how derived stores are protected, and what happens when a source is replaced, revoked, or deleted.

Use a map with owners and evidence.

For each path, record the source, destination, information class, purpose, identity, provider, retention, control, evidence reference, and accountable owner. If a path is unknown, label it unknown and resolve it before using information whose handling depends on the answer.

This describes generic review questions, not the behavior of a particular Providensi product or deployment. Actual capabilities and data paths require service-specific evidence.

04 / ACCESS IS NOT THE SAME AS ACTION

Permission to read is not permission to send.

A user can be entitled to see information without being authorized to transmit it elsewhere, alter a record, or instruct a shared operator to do so.

Permission layer	Review question	Evidence to seek
Source access	Can this requester retrieve each source and its derived content, including after permissions change?	Role mapping and tests of allowed and denied retrieval.
Processing access	May this information be used in this environment and by this operation?	Approved information classes, configuration, and transfer tests.
Action authority	May the service create a draft, change a source, update a record, or contact anyone?	Separate tool permissions and explicitly approved action scope.
Output access	Who can open the answer, exported file, shared project, or review packet?	Destination controls and recipient checks.
Administrative access	Who can change the boundaries, provision identities, or enter for support?	Restricted privileges, strong authentication, and reviewable activity records.

Do not turn the coordinator into an access shortcut

If an operator has broader rights than the requester, the workflow must still respect the requester’s and recipient’s entitlements. Asking the operator to retrieve a restricted document does not create authority to disclose it. Test the complete route, including summaries, cached answers, and exported files, rather than only the original folder permissions.

Use individually accountable identities where appropriate and define service-account and privileged-access ownership. Review enrollment, access changes, departure, recovery, and support access. Strong authentication is valuable, but proving who signed in does not establish that the identity has appropriate permissions for every source and action. [4]

Start with the narrowest useful authority.

For a preparation-only evaluation, allow approved-source reading and draft creation in a controlled workspace. Keep external sends and authoritative-record updates unavailable. Any broader service requires its own scope, controls, evidence, and bank approvals.

A prompt can describe the permitted task, but it does not replace tested access and action controls. Inspect actual outputs and effects; an assistant’s reassuring statement does not prove that a restriction held.

05 / DATA USE, RETENTION, AND EXIT

Ask about more than training.

“Not used for training” answers only one question. Information may still be retained or accessed for other purposes. Ask about the whole data life cycle.

Ask about	What the answer should distinguish
Permitted use	Providing the contracted service, service improvement, evaluation, abuse detection, analytics, and any human review. Identify which terms apply to each provider.
Operational retention	Files, prompts, outputs, history, metadata, diagnostics, caches, indexes, and backups. State the purpose and retention for each relevant copy.
Support access	Whether people can inspect content, under what approval, for how long, and through which controlled channel.
Deletion and legal hold	Active storage, derived stores, backup rotation, retention exceptions, hold obligations, and when deletion is effective or verifiable.
Ownership and portability	Rights to input and output, usable export formats, continuing access, exit assistance, deletion evidence, and subcontractor handling.

Ask which statement controls the arrangement

A sales statement, public privacy notice, product setting, and signed service term may describe different scope. Have the responsible reviewers identify the terms that govern the actual service and resolve conflicts explicitly. Do not assume a setting overrides a contract, or that a broad promise covers optional connected services.

Encryption helps protect information in transit or at rest, but does not by itself establish who can access readable content during processing or support. Likewise, a residency claim needs to distinguish storage, processing, backups, and administrative access. Identify the relevant locations and responsibilities rather than relying on a single regional label.

Test the usable part of the promise

Within authorized evaluation conditions, inspect representative logs and exports, revoke a test identity, and examine retrieval after access or source changes. Ask for evidence of deletion behavior and any limits to what the bank can independently verify. A successful deletion in a user interface is not proof that every retained copy has already disappeared.

Document legitimate limits rather than hiding them.

Backup retention, security logging, and legal holds may require different treatment. The review question is whether the documented arrangement meets the bank’s applicable needs and obligations, with accountable owners and agreed controls. It is not whether every service promises instant universal erasure.

NIST’s Generative AI Profile addresses privacy and information-security risks. The bank’s required retention, legal-hold, and privacy treatment depends on the information and actual use. [2]

06 / EVIDENCE THAT ANSWERS THE QUESTION

A document is useful only within its scope.

Due diligence combines design evidence, enforceable commitments, relevant independent assurance, and tests of the bank’s actual arrangement. None replaces all the others.

Evidence type	What it can help establish	What it does not establish alone
Service description and diagram	The proposed components, providers, information paths, roles, and intended controls.	That the installed configuration matches the design or operates effectively.
Contract and applicable terms	Agreed responsibilities, permitted uses, support, notices, remedies, and exit commitments.	That every control has been implemented or tested.
Independent assurance	Controls or management practices examined for identified services, locations, and periods.	Universal security, every deployment’s behavior, or regulatory approval.
Configuration and local testing	Observed behavior of the specific environment under documented test conditions.	All future behavior, undisclosed providers, or contractual rights.
Operating and recovery records	How service, incidents, changes, access, and recovery have actually been handled.	That a different future workload will have identical outcomes.

Read beyond the cover of the report

For a relevant SOC report, assessment, or certification, examine the named service, scope, date or period, exceptions, excluded components, and responsibilities placed on customers. Determine how subcontracted services are treated. A report for a hosted offering may not cover a separately installed configuration, and evidence can become less relevant after material changes. [1]

When evidence is unavailable, ask for a reason and an appropriate alternative. A controlled review of sensitive material may be more suitable than distributing the report widely. If the question still cannot be answered, record that gap and its consequence. Do not quietly transform “not supplied” into “not applicable” or presume a certification exists.

Use evidence states that mean something.

Requested, received, scope reviewed, tested, gap identified, and accepted are different states. Record who evaluated the evidence, which requirement it addresses, its limits, the residual issue, and the person authorized to make the decision.

No particular report is a universal requirement for every AI service. Select evidence proportionate to the activity and the bank’s review needs. A completed questionnaire or a provider’s self-attestation is not independent assurance.

07 / AI-SPECIFIC FAILURE MODES

Test the failure you need to prevent.

Traditional access, change, continuity, and security controls remain relevant. AI also introduces ways for plausible answers or untrusted content to misdirect the workflow.

Failure mode	Bounded evaluation question	Evidence to retain
False or unsupported answer	Does the system expose uncertainty and cite a real passage that supports the conclusion?	Source versions, expected findings, reviewer checks, and material errors.
Instructions in retrieved content	Can untrusted source text redirect the assignment, expose information, or invoke an excluded action?	Approved test scope, actual attempted effects, control results, and limits.
Unauthorized retrieval	Can a user obtain restricted content through a summary, search, history, or derived store?	Identity and role, allowed and denied cases, access changes, and observed outputs.
Wrong external effect	Can an action occur without the required scope, recipient validation, or review?	Tool settings, allowed and denied tests, activity records, and independently checked effects. Verify excluded actions are blocked without enabling live external actions.
Human overreliance	Can a qualified reviewer find and reject a plausible but material error?	Review criteria, source access, disagreement, correction, and acceptance records.

Keep testing authorized and representative

Use an approved environment with synthetic or explicitly permitted data. Include ordinary work, difficult cases, missing evidence, conflicting versions, interruptions, and permission changes. Do not conduct unapproved production probing or introduce hostile material into shared systems. The relevant owners agree on the test scope and containment before it runs.

Inspect the resulting files, records, access events, and transfers where the question depends on them. A verbal refusal does not prove that a tool never ran, and a statement of success does not prove the correct file was created. Record serious failures separately from average answer-quality scores.

A useful test report includes its limits.

Name the configuration, identities, source set, expected behavior, observed result, unresolved findings, and retest trigger. “No prohibited transfer observed in the tested cases” is narrower and more supportable than “information can never leave.”

NIST identifies confabulation, privacy exposure, human-AI interaction risks, and prompt injection, among other concerns. These suggested evaluations are an educational response, not a certification or complete security test program. [2]

08 / CIP AND CYBERSECURITY

Two related concerns, two different questions.

Knowing the customer’s identity and protecting information or system access are connected responsibilities. Completing one does not establish that the other is satisfied.

Compare	Customer Identification Program	Cybersecurity and access
Core question	Does the bank have the required basis for a reasonable belief that it knows the customer’s true identity?	Are information and services protected, and are identities allowed only the appropriate access and actions?
Relevant evidence	Applicable identifying information, verification methods and results, discrepancy handling, and required records.	Access design, authentication, permissions, protected transfers, monitoring, and response evidence.
Accountable expertise	The bank’s BSA/AML and designated business owners applying its approved CIP and applicable requirements.	Security, technology, data and system owners, with relevant risk and compliance involvement.
What AI preparation may do	Organize authorized source evidence and identify missing or conflicting items for human review.	Organize relevant control evidence and findings within a separately defined review scope.
What it does not prove	A tidy packet does not establish successful identity verification or authorize account opening.	A completed access check does not establish CIP compliance or guarantee information security.

Avoid a generic “CIP and cyber cleared” status

The FFIEC CIP section explains risk-based identification and verification aimed at a reasonable belief of true identity. Authentication guidance addresses risk-based access and layered safeguards for customers, staff, third parties, and systems. An authenticated login is not, by itself, proof that the bank has completed its CIP responsibilities. [3, 4]

If a future assignment prepares both kinds of material, maintain separate questions, source evidence, reviewers, and decisions. A missing identity-verification record goes to the designated CIP owner. An unapproved support export goes to security and the relevant information owner. Neither should be hidden because a combined dashboard appears complete.

Keep preparation separate from determination.

For an initial evaluation, use synthetic examples and do not let the assistant declare a customer verified, approve an account, certify a control, or close a security finding. Those determinations remain with authorized bank processes.

This section is not a complete statement of CIP, customer due diligence, authentication, or cybersecurity obligations. Current rules, exceptions, relief, and the bank’s approved procedures must be evaluated by the responsible teams. Customer due diligence is broader than this CIP comparison.

09 / OPERATING AND CONTRACTUAL EVIDENCE

Review the service when something goes wrong.

Support, updates, interruptions, and provider dependencies can change the information boundary long after an initial demonstration succeeds.

Review area	Questions for the actual service	Useful evidence
Support and administration	Who may connect, view content, export diagnostics, or alter settings? How is access approved and ended?	Access procedure, activity records, revocation tests, and support terms.
Updates and change	Who controls updates, new connections, configuration drift, and changes to data handling?	Change notices, ownership, testing, rollback, and approval arrangements.
Incident handling	Who reports what, through which route, with what evidence and agreed timing?	Contract terms and tested bank/vendor escalation procedures.
Continuity and recovery	What happens to unfinished work? Can the bank restore usable records and continue manually?	Recovery objectives, exercises, results, and a realistic fallback.
Provider dependence	Can the provider sustain the service, and which subcontractors or concentrated dependencies matter?	Appropriate financial, operational, continuity, and subcontractor evidence.

Write commitments that match responsibility

Have the bank’s appropriate reviewers address service scope, data use, access, subcontractors, assurance rights, change information, support, incident communication, continuity, and exit. Clarify which evidence the provider will make available and which controls the bank must implement. A helpful demonstration is not a contractual commitment. [1]

Set operational expectations for the intended use rather than importing a generic availability promise. Recovery of the application, source collection, permissions, indexes, and accepted work may involve different steps. Validate what a recovery test actually restored and whether the bank could use it.

Do not confuse a negotiated notice with a legal obligation.

Vendor-to-bank incident terms and the bank’s own regulatory or customer-notification duties can differ. The responsible teams determine applicable triggers and deadlines. This guide does not prescribe a universal notification period.

A synthetic pilot can reduce exposure while evaluating usefulness, but it does not eliminate procurement, security, licensing, or other applicable approvals. Missing evidence remains visible with a consequence and an owner.

10 / FICTIONAL REVIEW: THE INFORMATION MAP

Map the bank-hosted proposal.

The following arrangement, documents, findings, and decisions are entirely fictional. They illustrate the review method, not the design or performance of a real vendor or Providensi deployment.

A bank team considers an internal procedure-comparison assistant. The proposed first task uses synthetic procedure files, reads them from a controlled folder, and creates a draft for a policy owner. It cannot update authoritative records or send messages. Staff-only use does not settle the information path, so the reviewers ask for a complete service map.

Proposed component	What the fictional evidence says	Review question
Document workspace	Source copies and drafts are stored on a bank-controlled machine.	Are permissions and output destinations correctly restricted?
Local processing	The service description says the initial comparison uses local processing.	Does the installed configuration behave as described in the bounded tests?
Optional web research	An external search path is available but not needed for the first task.	Is it disabled and restricted in the evaluation configuration, including alternate invocation routes?
Diagnostics	A support bundle may contain excerpts; the first description does not define which logs are included.	What content is recorded, who can export it, and what terms apply?
Backup and support	The bank backs up the workspace; a provider can be granted remote support access.	Who approves access, what can support see, and how are retained copies handled?

Turn a reassuring label into specific questions

The proposal is not rejected merely because an optional path exists. Nor is it accepted merely because the principal work is described as local. The reviewers separate the base workload, optional external function, logs, backup, and support access. Each receives an owner and an evidence request.

They require a synthetic-only configuration with external research restricted, support exports and all provider access unavailable, and a controlled draft workspace. Before testing, they document trial logs, indexes, caches, and backups, including access and retention. Prerequisite restrictions must be demonstrated. Production handling questions remain open; the word synthetic does not waive them.

The map creates the evidence agenda.

The source-permission test answers who can retrieve a file. The transfer test addresses the optional route. Inspection of representative logs answers what is recorded. Contract review addresses permitted use and retention. No one result substitutes for the whole review.

11 / FICTIONAL REVIEW: EVIDENCE AND DECISION

Approve only the tested scope.

This continues the invented example. Every finding and decision below is fictional, not an observed vendor result or a recommendation to accept these conditions.

Review item	Fictional finding	Decision and owner
Processing and task authority	Configuration review and bounded tests supported local processing, approved reads and drafts, and denied source writes and external sends.	Technology and security retain configuration and test records; conclusions stay within the tested conditions.
Access and optional paths	Allowed and denied identities behaved as expected. External research, all provider access, and support export were unavailable.	Security retains restrictions, including no temporary support access, and checks output permissions.
Trial copies and records	Trial logs, indexes/caches, and backups had documented destinations, access, and retention accepted for synthetic evaluation.	Technology records every relevant store. This does not resolve production handling.
Assurance applicability	A supplied report covers a different hosted service, not the installed comparison setup.	Vendor management requests relevant evidence or a justified alternative. Gap remains open.
Production handling	Production content retention and support terms remain incomplete.	Legal and security resolve terms and controls before any production decision.

The completed fictional decision

The authorized bank owners permit only approved synthetic-source reading and controlled draft creation, with a policy-owner reviewer and a manual fallback. No live bank sources, real customer or internal documents, external actions, provider access (including temporary support), or support exports are approved.

The fictional authorization expires October 20, 2026. Stop on non-synthetic access, an unapproved transfer, provider access, or departure from the approved configuration. Restart requires the designated reviewers' approval. Vendor management reviews the assurance gap, and legal/security review production gaps, by that date. Neither closes automatically; broader scope requires a separate decision.

Three states remain deliberately separate.

The synthetic evaluation is authorized. The comparison's usefulness is still to be assessed. The production arrangement is not approved. A single "vendor approved" field would conceal those distinctions.

The assurance mismatch and production data-handling questions remain open. A limited evaluation is not an exemption from applicable requirements. Each bank determines whether this type of evaluation is appropriate and who can approve it.

12 / MONITORING AND EXIT

Keep evidence tied to the service.

A review can become stale when the workflow, information, users, provider, or technical configuration changes, even if the product name stays the same.

Trigger or recurring review	What to reconsider
New information or source collection	Data classification, source-owner permission, processing paths, retention, and permitted recipients.
New user group or action	Entitlements, authentication, tool authority, review capacity, and possible downstream effects.
Service or provider change	Dependencies, subcontractors, terms, locations, control coverage, and evidence relevance.
Material failure or incident	Containment, affected work, notification duties, correction, causes, and conditions for restart.
Periodic operating review	Quality, access, usage, support, open findings, financial and operational viability, and continuing need.
Exit or replacement	Usable exports, access revocation, records retention, provider-held copies, continuity, and transition responsibilities.

Give every open item a consequence

For each unresolved issue, record the affected scope, accountable owner, required evidence, due date, and what remains restricted until resolution. If a review date is missed, apply the bank’s established escalation rather than allowing the status to disappear into routine renewals. A risk acceptance has a specific owner and boundary; it is not a general exemption.

Practice the exit while the service still works

Confirm that the bank can retrieve accepted work, source references, necessary records, and usable configuration information under agreed rights. Test revocation and a workable manual or replacement process. Address derived stores, support copies, and contractual retention exceptions. Changing vendors does not itself delete the old provider’s retained information.

Monitor the actual arrangement rather than repeatedly collecting the same questionnaire. Review evidence updates against earlier limitations and known findings. A new report can be useful without covering every open question, and an unchanged report may not support a newly expanded service. [1]

Expansion is a new question, not an automatic reward.

A successful comparison of synthetic files can justify considering the next step. It does not authorize customer records, wider retrieval, messages, or system updates. Define the new benefit and boundary, then obtain the evidence and decisions for that changed scope.

13 / SUPPORTING TOOL: EVIDENCE REGISTER

Use one record for the requirement, evidence, and gap.

Use this page for a material review question, or repeat its fields in the bank's approved vendor-management system. Keep restricted evidence in its authorized repository.

Review field	Entry or controlled reference
Service / version / proposed use	_____ _____
Information class and affected path	_____
Specific requirement or review question	_____ _____
Evidence reference / provider / evidence date / status	_____ _____
Scope, period, limits / evaluator / assessment date	_____ _____
Configuration test and observed result	_____ _____
Remaining gap and consequence	_____ _____
Responsible owner / next action / due date	_____
Decision / approver / decision date / conditions / scope	_____ _____
Review date and change or retest trigger	_____

Before closing the item

- The evidence covers the actual service and question, not merely a similarly named product.
- Received, reviewed, tested, and accepted are not used interchangeably.
- A gap has a consequence, an owner, and an explicit decision; missing evidence is not treated as approval.
- Conditions are checked and the decision authority is recorded. Any legal requirement remains applicable.

This register organizes a review; it does not approve the vendor, establish compliance, or demonstrate a control by itself. The Word edition is editable. The PDF is intended for printing or annotation, not automated scoring.

14 / MAKE THE REVIEW USABLE

Finish with a bounded decision, not a stack of files.

A reviewer who was not in the demonstration should be able to understand what may proceed, why, and what remains restricted.

Decision summary	What to state plainly
Proposed service	The work, users, information, environment, provider dependencies, and permitted operations.
Evidence assessed	What was reviewed or tested, by whom, for which configuration, and with which limitations.
Unresolved issues	The gap, consequence, affected scope, owner, due date, and next decision needed.
Disposition	Proceed within defined conditions, revise and retest, hold, or decline, using the bank's decision authority.
Continuing obligations	Monitoring, change review, incident routing, records, exit planning, and triggers for suspension or renewed approval.

Bring the right questions to the next conversation

For a scoping discussion with Providensi, begin with a general workflow, the information classes involved, required reviewers, intended operating environment, and the evidence your bank needs. Use synthetic or appropriately approved examples. There is no need to provide customer files or credentials merely to describe the business question.

Discuss an evidence-based AI evaluation with Providensi.

Ask what is included in the proposed arrangement, what must be separately configured or contracted, and which questions remain open. Confirm actual capability, information handling, pricing, support, assurance, and responsibilities for the service under consideration. This guide is not a product warranty or assurance report.

A note on changing guidance

The September 11, 2026 OCC notice reviewed for this guide describes proposed third-party risk-management guidance and a request for comment. A proposal is not final guidance. The May 2024 community-bank guide is cited here for its published educational principles, not as a complete statement of every current obligation. Confirm applicable requirements and subsequent developments before a live decision. [1, 5]

This resource complements A Bank Leader's Guide to Practical AI, Measuring the Value of AI in Your Bank, and The Bank AI Help Desk Playbook. The next resource addresses planning a bank-hosted deployment. No regulatory approval, completed customer engagement, or security certification is represented.

SOURCES / SCOPE

References and reading notes.

References checked October 6, 2026. The questions, examples, decision tools, and information-map method are Providensi's educational synthesis, not agency-issued requirements.

[1] Third-Party Risk Management: A Guide for Community Banks

Federal Reserve, FDIC, and OCC • May 2024

Published guidance resource covering planning, due diligence, contracting, monitoring, and termination. Printed pages 1–2 explain continuing bank responsibility and its status; pages 8–18 discuss evidence and operating arrangements. It is not a checklist or regulatory safe harbor. See the proposal-status note on page 15.

[2] Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile

NIST AI 600-1 • July 2024

Sections 2.2, 2.4, 2.7–2.9, and 2.12 address false content, privacy, human reliance, information integrity, security, and component risks. Its suggested actions support voluntary risk-management work, not certification of a product or deployment.

[3] Customer Identification Program

FFIEC BSA/AML Examination Manual • online section reviewed October 6, 2026

Explains the CIP framework, reasonable belief of customer identity, risk-based verification, records, and bank responsibilities. This guide does not summarize every collection rule, exception, relief, or customer due diligence obligation.

[4] Authentication and Access to Financial Institution Services and Systems

FFIEC statement; OCC Bulletin 2021-36 • August 11, 2021

Addresses risk-based authentication, access, and layered safeguards across financial-institution users and systems. It is guidance and does not establish completion of the bank's separate CIP responsibilities.

[5] Third-Party Risk Management: Proposed Guidance and Request for Comment

OCC Bulletin 2026-46 • September 11, 2026

The notice reviewed is explicitly proposed guidance. It is included to distinguish a proposal from a final change, not to treat proposed provisions as existing mandatory requirements.

Educational scope

This guide is not legal advice, a complete control framework, an independent security assessment, or a guarantee of compliance or performance. The bank's responsible teams determine applicable obligations, required evidence, contract treatment, acceptable use, and approval for its actual arrangement.